- Open redirect attacks use the common `returnURL` mechanism after logging in to redirect users to malicious websites. You can prevent this attack by ensuring that you redirect only to local URLs—URLs that belong to your app.
- Insecure direct object references are a common problem where you expose the ID of database entities in the URL. You should always verify that users have permission to access or change the requested resource by using resource-based authorization in your action methods.
- SQL injection attacks are a common attack vector when you build SQL requests manually. Always use parameterized queries when building requests or use a framework like EF Core, which isn't vulnerable to SQL injection.
- The most sensitive data in your app is often the data of your users. Mitigate this risk by storing only data that you need. Ensure that you store passwords only as a hash, protect against weak or compromised passwords, and provide the option for MFA. ASP.NET Core Identity provides all of this out of the box, so it's a great choice if you need to create an identity provider.

---

1. In 2020 the National Institute of Standards and Technology (NIST) updated its Digital Identity Guidelines on handling user details, which contains some great advice. See http://mng.bz/6gRA.